

# PRD — Livraria Digital com Oblivious Transfer

Sep 27, 2026 · @M4GAL

## Visão geral e problema

Vamos construir uma livraria digital em que a loja recebe o pagamento, mas não fica sabendo quais livros o cliente comprou. Para isso, a venda das chaves dos livros cifrados usa Oblivious Transfer (OT).

**Problema.** Nas lojas online atuais, cada compra alimenta perfis de consumo e anúncios. O cliente não tem como comprar um bem digital sem entregar suas preferências ao vendedor.

**Proposta.** O cliente escolhe um grupo de livros de mesmo preço e paga por N deles. Por OT, recebe as chaves dos N livros escolhidos sem que o site saiba quais são. Os livros cifrados são baixados de uma CDN com tokens de assinatura cega e descriptografados offline, em um executável local.

Fonte: *Especificação Detalhada* do TCC (PCS/Poli-USP, 2026), versão 2.

## Objetivos e não objetivos

A meta é um protótipo funcional que demonstre a compra privada ponta a ponta, do catálogo à leitura offline.

### Objetivos

1. O site não consegue identificar quais livros um comprador adquiriu ou acessou.
2. A loja recebe o pagamento e a CDN é remunerada pelos downloads, sem que isso revele a escolha do cliente.
3. O cliente compra sem criar conta, informando apenas o e-mail.
4. O cliente descriptografa os livros comprados sem acesso à internet, e nenhum outro.
5. Testes de segurança e desempenho mostram que as preferências não são rastreáveis e que as metas de tempo são atendidas.

### Não objetivos

- Proteger contra conluio entre site e CDN. A não conivência é uma premissa garantida por auditoria.

- Esconder do site *quem* comprou. O site conhece o e-mail e o pagamento; só não conhece *o quê*.
- Contas de cliente, histórico de compras, recomendações ou qualquer perfil de consumo.
- Preços livres por livro. Os preços pertencem a um conjunto discreto, para formar grupos de mesmo preço.

## Usuários

Três papéis usam o sistema. Só o cliente tem uma jornada de privacidade; os outros dois operam a plataforma.

| Papel          | O que precisa fazer                                                               | O que pode saber                                                |
|----------------|-----------------------------------------------------------------------------------|-----------------------------------------------------------------|
| Cliente        | Buscar livros, comprar N itens de um grupo sem conta, baixar na CDN e ler offline | Tudo sobre as próprias compras                                  |
| Administrador  | Gerir a própria conta, o catálogo e os preços discretos                           | Catálogo e pagamentos; nunca quais livros cada cliente escolheu |
| CDN (operador) | Entregar livros cifrados mediante token e reportar o uso para ser remunerada      | Quais livros foram baixados; nunca quem os comprou              |

## Arquitetura e fluxo de compra

O sistema tem três componentes (site, CDN e executável local) e um serviço externo, o gateway de pagamento. Cada um conhece só uma parte da compra.

## O site sabe quem comprou; a CDN sabe o que foi baixado



- 1 O executável local gera a requisição de OT e guarda o segredo dela.
- 2 O cliente envia ao site o e-mail, a requisição de OT e N valores cegados.
- 3 O site cobra a compra pelo gateway de pagamento.
- 4 Pago, o site devolve a resposta do OT (também por e-mail) e N assinaturas cegas.
- 5 O cliente troca cada token por um livro cifrado na CDN.
- 6 A CDN reporta ao site só os tokens usados e a quantidade, para ser paga.
- 7 Offline, o executável extrai as chaves com o segredo e decifra os livros.

arquitetura e fluxo de compra · 3 componentes, 7 passos

A chave final nunca passa pelo site: ela só aparece no passo 7, dentro do executável, que é o único a guardar o segredo da requisição.

## Requisitos funcionais

São 18 requisitos (RF01–RF18 da especificação), agrupados pelo componente que os implementa. A prioridade é uma proposta deste PRD, não vem da especificação.

| ID   | Componente | Requisito                                     | Critério de aceite                                                | Prioridade |
|------|------------|-----------------------------------------------|-------------------------------------------------------------------|------------|
| RF01 | Site       | Cadastro, login e gestão de administradores   | Apenas administradores autenticados acessam a área administrativa | Essencial  |
| RF02 | Site       | Cadastrar, editar, consultar e remover livros | Mudanças no catálogo aparecem na busca do cliente                 | Essencial  |

| ID   | Componente        | Requisito                                                     | Critério de aceite                                              | Prioridade |
|------|-------------------|---------------------------------------------------------------|-----------------------------------------------------------------|------------|
| RF03 | Site              | Preço de cada livro dentro de um conjunto pré-definido        | Não é possível salvar um preço fora do conjunto                 | Essencial  |
| RF04 | Site              | Busca por título, autor, categoria e preço                    | Resultado em até 5 s (RNF02)                                    | Desejável  |
| RF05 | Site              | Compra sem criar conta                                        | O fluxo termina sem cadastro nem senha                          | Essencial  |
| RF06 | Site              | E-mail obrigatório para receber a resposta do OT              | A compra não avança sem um e-mail válido                        | Essencial  |
| RF07 | Site + executável | Comprar N livros de um grupo de mesmo preço sem revelar quais | Nada do que o site recebe permite deduzir os índices escolhidos | Essencial  |
| RF08 | Site              | Entregar a resposta do OT e dados relacionados                | O cliente extrai as N chaves; o site não conhece nenhuma delas  | Essencial  |
| RF09 | Todos             | Arquitetura com site, CDN e executável local                  | Os três componentes são implantados e operam separados          | Essencial  |
| RF13 | Site              | Pagamento via gateway, com status devolvido ao cliente        | Pagamento aprovado libera o passo 4; recusado mostra falha      | Essencial  |
| RF14 | Site              | Enviar a resposta do OT por e-mail após o pagamento           | E-mail chega em até 1 min (RNF04) e não contém a chave          | Essencial  |
| RF15 | Site              | Reenviar a resposta do OT ao mesmo e-mail, dentro de um prazo | Reenvio só para o e-mail original e dentro do prazo             | Desejável  |
| RF16 | Site              | Assinar às cegas N valores, gerando N tokens                  | O site não consegue ligar um token à sessão que o assinou       | Essencial  |
| RF17 | CDN               | Entregar um livro só com token válido e não usado             | Token inválido ou repetido é recusado                           | Essencial  |

| ID   | Componente | Requisito                                                      | Critério de aceite                                       | Prioridade |
|------|------------|----------------------------------------------------------------|----------------------------------------------------------|------------|
| RF18 | CDN        | Reportar ao site os tokens usados e a quantidade               | O reporte não traz livro por token nem horários          | Essencial  |
| RF10 | Executável | Descriptografar offline com o livro cifrado e a resposta do OT | Funciona sem nenhuma conexão de rede                     | Essencial  |
| RF11 | Executável | Gerar a requisição de OT e guardar o segredo dela              | Sem o segredo local, a resposta do OT não revela a chave | Essencial  |
| RF12 | Executável | Não decifrar livros não comprados                              | Um livro fora dos N escolhidos resulta em acesso negado  | Essencial  |

## Requisitos não funcionais e métricas de sucesso

O protótipo é bem-sucedido se atingir as oito metas abaixo e passar nos testes de privacidade.

| ID    | Atributo                | Meta                                                    | Como medir                                             |
|-------|-------------------------|---------------------------------------------------------|--------------------------------------------------------|
| RNF01 | Segurança criptográfica | $\geq 128$ bits (ataque exige $\sim 2^{128}$ operações) | Tamanho de parâmetros das primitivas escolhidas        |
| RNF02 | Busca                   | $\leq 5$ s por consulta                                 | Tempo de resposta do endpoint de busca                 |
| RNF03 | Finalização da compra   | $\leq 1$ min                                            | Do envio da requisição de OT até a resposta ao cliente |
| RNF04 | Envio do e-mail         | $\leq 1$ min após o pagamento                           | Da confirmação do gateway ao envio do e-mail           |
| RNF05 | Capacidade              | $\geq 600$ transações/min                               | Teste de carga no site                                 |
| RNF06 | Disponibilidade         | $\geq 99\%$ de uptime por mês                           | Monitoramento do site e da CDN                         |
| RNF07 | Usabilidade             | $\geq 99\%$ das compras concluídas sem suporte          | Taxa de conclusão do fluxo de compra                   |
| RNF08 | Manutenibilidade        | Mudança simples em $\leq 8$ h úteis                     | Tempo registrado por alteração                         |

Além das metas, a avaliação precisa mostrar que o site não infere a escolha do cliente a partir do que recebe, incluindo o reporte da CDN.

## Modelo de ameaça e garantias de privacidade

A privacidade vem da separação de conhecimento: nenhuma parte sozinha liga *quem* comprou a *o quê* foi comprado. Isso vale enquanto site e CDN não forem coniventes, o que é garantido por auditoria. Essa separação é o desenho do sistema, não uma falha a corrigir.

| Parte                      | Sabe                                    | Não sabe                              | Garantido por                      |
|----------------------------|-----------------------------------------|---------------------------------------|------------------------------------|
| Site                       | E-mail, pagamento, grupo e quantidade N | Quais livros do grupo; a chave final  | OT (RF07, RF08)                    |
| Site, ao receber o reporte | Tokens usados e quantidade              | Em qual compra cada token foi emitido | Assinatura cega (RF16)             |
| CDN                        | Quais livros foram baixados, por token  | Quem comprou                          | Tokens sem identidade (RF16, RF17) |

| Parte             | Sabe                       | Não sabe                     | Garantido por                         |
|-------------------|----------------------------|------------------------------|---------------------------------------|
| Gateway           | Valor e dados de pagamento | Quais livros                 | Cobrança pelo grupo, não pelo livro   |
| E-mail do cliente | Resposta do OT             | A chave, sem o segredo local | Segredo guardado no executável (RF11) |

### Regras de design que decorrem daqui

- O reporte CDN → site leva só tokens e quantidade: nunca o livro de cada token nem horários que permitam correlação (RF18).
- E-mail (RF14) e reenvio (RF15) levam a resposta do OT, nunca a chave, que o site desconhece.
- Perder o segredo local significa perder o acesso: o reenvio da resposta do OT não o recupera.

## Premissas, riscos e questões em aberto

### Premissas e dependências

- Site e CDN não são coniventes, e uma auditoria garante isso.
- Existe um gateway de pagamento integrável ao site.
- O cliente consegue levar arquivos entre o navegador e o executável offline (requisição, resposta do OT, livros).

### Riscos

| Risco                          | Efeito                                                                  | Mitigação proposta                                        |
|--------------------------------|-------------------------------------------------------------------------|-----------------------------------------------------------|
| OT de N itens caro demais      | Compra passa de 1 min (RNF03) ou não chega a 600 transações/min (RNF05) | Avaliar OT Extension e k-out-of-n cedo, com medição       |
| Grupos de mesmo preço pequenos | Com poucos livros no grupo, o site adivinha a escolha com facilidade    | Definir tamanho mínimo de grupo                           |
| Reporte da CDN vaza tempo      | Enviar tokens logo após o download permite correlacionar com a compra   | Reportar em lotes, sem horários                           |
| Uso de Rabin fora da condição  | Com $p$ ou $q \not\equiv 3 \pmod{4}$ a raiz calculada está errada       | Impor $p \equiv q \equiv 3 \pmod{4}$ na geração de chaves |

| Risco                         | Efeito                           | Mitigação proposta                      |
|-------------------------------|----------------------------------|-----------------------------------------|
| Cliente perde o segredo local | Livros comprados ficam ilegíveis | Orientar backup do estado do executável |

### Questões em aberto

- ☐ Qual variante de OT usar: 1-out-of-n repetido, k-out-of-n ou GOT?
- ☐ Qual o tamanho mínimo de um grupo de mesmo preço?
- ☐ Qual o prazo de reenvio da resposta do OT (RF15)?
- ☐ Cada token vale para um único download, ou permite baixar de novo o mesmo livro?
- ☐ Com que frequência a CDN reporta, e como é remunerada por token?
- ☐ Qual algoritmo simétrico cifra os livros, dentro dos 128 bits de RNF01?

## Escopo do MVP e marcos

O MVP é a compra privada ponta a ponta de um grupo de livros: todos os requisitos essenciais da tabela de requisitos funcionais. A busca com todos os filtros (RF04) e o reenvio (RF15) podem entrar depois do primeiro fluxo completo.

**Marcos**, conforme as fases do método do TCC (a especificação ainda não traz datas):

1. **Fundamentação teórica** — OT e variantes, OT Extension, Rabin. Concluída.
2. **Especificação de requisitos** — RF01–RF18 e RNF01–RNF08. Concluída (versão 2).
3. **Projeto da solução** — escolha da variante de OT, formato dos artefatos e dos tokens, tamanho dos grupos.
4. **Implementação incremental**, nesta ordem:
  - a. catálogo e cadastro de livros;
  - b. fluxo de compra com e-mail e gateway;
  - c. OT da escolha privada;
  - d. tokens com assinatura cega e entrega pela CDN;
  - e. executável local: segredo, extração da chave e descriptografia.
5. **Testes e avaliação** — atendimento aos requisitos, privacidade e desempenho (RNF02–RNF05).
6. **Consolidação** — análise dos resultados, limitações e continuidade.